

AWS
re:Invent

DECEMBER 1 - 5, 2025 | LAS VEGAS, NV

AWS re:Invent 2025 reCap

Security & Partners

Keynote with Matt Garman



**BUILDING IN SECURITY
FROM THE GROUND UP**



AI Security



AI Security launches

SECURITY FOR AI & AI FOR SECURITY



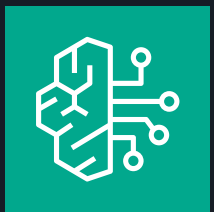
AWS Security Agent (Preview)

A new application security agent that accelerates secure development by providing proactive security expertise across architecture design, code review, and context-aware penetration testing



AWS Security Incident Response – AI investigative agent

An agentic AI-powered capability that automatically gathers and analyzes security evidence across multiple AWS data sources, then presents findings in clear, actionable summaries—reducing security event investigation time from hours to minutes.



Amazon Bedrock AgentCore Policy and Evaluations

- **Identity:** Supports custom claims for enhanced authentication rules across multi-tenant environments while maintaining seamless integration with your chosen identity provider.
- **Gateway:** Policy Engine launch for fine-grained access controls
- **Gateway:** 3LO (Three-Legged OAuth) support for Gateway Tools

AWS Security Agent (Preview)

SHIP WITH CONFIDENCE. THE FRONTIER AGENT FOR MORE SECURE APPS



- ✓ Secure every application proactively
- ✓ Get expert, tailored security guidance
- ✓ Conduct penetration testing on-demand

AWS Security Agent Preview

Design Review

- ✓ Proactively scans design documents before code development begins
- ✓ Catches compliance issues early by validating against team best practices
- ✓ Prevents costly rework and ensures security standards are met from day one

Code Review

Penetration Test

The screenshot shows the 'Design Review' interface of the AWS Security Agent. It features a 'Design review name' section with a text input field containing 'AnyCompany CRM Events Functionality Review'. Below this is a 'Files to review' section with a note: 'A maximum of 5 files (2MB each) may be uploaded per design review.' There is a large light blue box with the text 'Drag and drop files here (PDF, DOC, DOCX, PNG and JPG).' and a '+ Choose files' button. A warning message states: 'DOC and DOCX files are analyzed for text only. Images must be uploaded as PNG, JPG or embedded in PDFs.' Below the warning, there is a list of three files: 'CRM_API_Design.pdf', 'CRM_Requirements.docx', and 'CRM_BusinessLogic.docx'. Each file entry has a close button (X) on the right.

File Name	Action
CRM_API_Design.pdf	×
CRM_Requirements.docx	×
CRM_BusinessLogic.docx	×

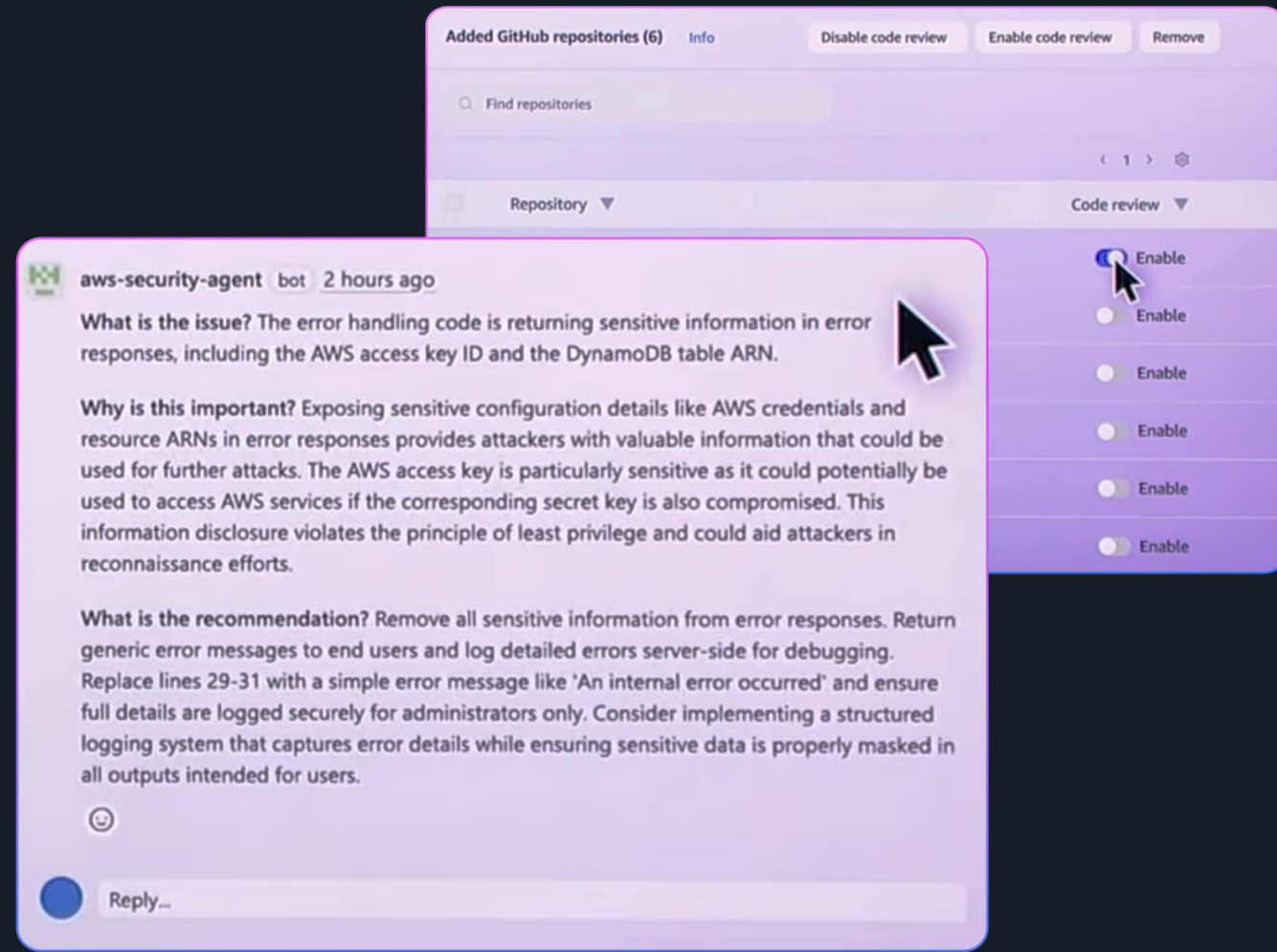
AWS Security Agent (Preview)

Design Review

Code Review

Penetration Test

- ✓ Automatically reviews code against security requirements
- ✓ Flags issues with clear, actionable fix recommendations
- ✓ Initiate penetration tests instantly when code is complete



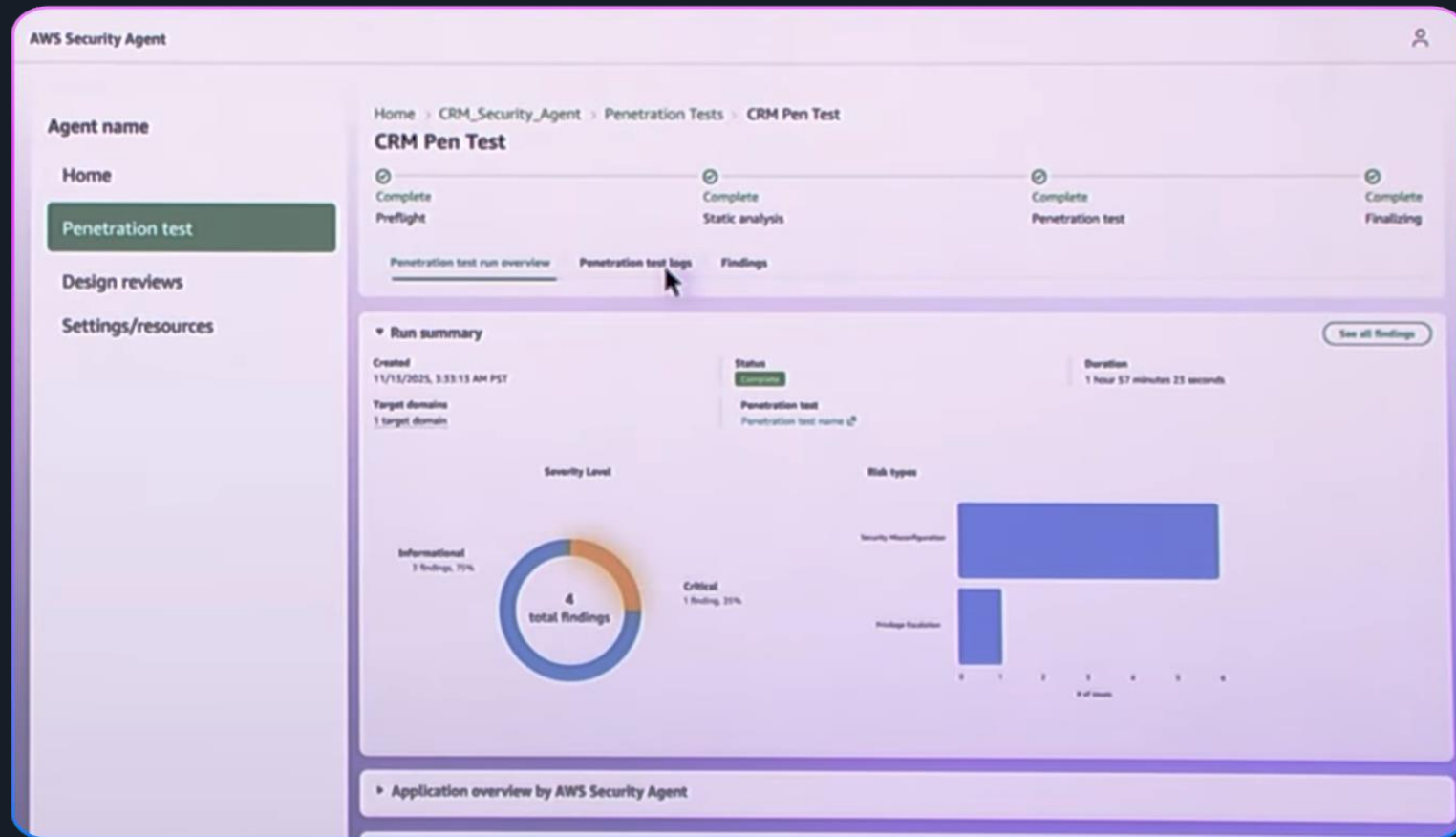
AWS Security Agent (Preview)

Design Review

- ✓ Run multiple pen tests simultaneously across all applications
- ✓ Scale testing to match your deployment velocity
- ✓ Write code faster, deploy faster with built-in security confidence

Code Review

Penetration Test



AWS Security Agent

Proactive AI-powered security throughout the development lifecycle

AWS Security Agent automatically enforces your organization's security requirements across design and code reviews, and provides on-demand penetration testing to discover verified vulnerabilities before they reach production.

How it works

Review designs before implementation

Define your security requirements once in the AWS Console, and AWS Security Agent automatically evaluates design documents against your organizational standards. Upload architectural documents to the web application to catch security issues early when changes are least expensive, eliminating costly late-stage rework and keeping pace with development velocity.

Analyze code in pull requests

AWS Security Agent automatically reviews pull requests against your defined security requirements and common vulnerabilities. Developers receive tailored remediation guidance directly in GitHub while your AppSec team maintains consistent security enforcement across repositories.

Pentest applications on demand

Request penetration testing whenever you need it through the web application. AWS Security Agent discovers and validates vulnerabilities through tailored attack scenarios, providing reproducible exploit details and ready-to-implement fixes that accelerate remediation.

Get started with AWS Security Agent

Create your first agent space and perform security reviews on your applications.

[Set up AWS Security Agent](#)

Getting started [↗](#)

[Perform a design review](#) [↗](#)

[Getting started](#) [↗](#)

[Execute a penetration test](#) [↗](#)

More resources [↗](#)

[Documentation](#) [↗](#)

[Pricing](#) [↗](#)

[AWS Agents forum](#) [↗](#)

[Contact us](#) [↗](#)

Set up AWS Security Agent [Info](#)

When you choose Set up, AWS Security Agent will create your agent, and establish a web application where your users can use the agent for design review and penetration test started with Hobbes experience and create your first agent.

Agent Configuration

Agent space name

The agent space name is displayed to users in the web app.

Enter a name for your agent space

0 of 255 characters.

Description - *optional*

The agent space description assists in distinguishing agent purpose and is displayed to users in the web app.

Enter a description for your agent

0 of 500 characters.

User access configuration

Choose how users access your agent space in the web app.

☒ **Single-sign (SSO) on with IAM Identity Center**

Enable SSO access for your team. AWS Security Agent integrates with IAM Identity Center to either create an account instance in US East (N. Virginia), or connect to an existing organization instance if available in that Region.

[Learn more about account instances](#) ↗

☐ **IAM users**

Only Identity and Access Management (IAM) users of this AWS account can access your AWS Security Agent web application.

▶ Service access - *optional*

ⓘ **Configure additional capabilities after setup**

After initial setup, you'll have the option to configure capabilities for your users including penetration testing and security reviews.

[Cancel](#)

[Set up AWS Security Agent](#)

Security requirements [Info](#)

Security requirements are used by AWS Security Agent to analyze compliance in design review and code reviews. Choose from AWS-managed requirements or create custom ones tailored to your standards.

[Managed security requirements](#)

[Custom security requirements](#)

[Enabled security requirements](#)

Managed security requirements (11)

Customize

Disable

Enable

AWS-provided security requirements based on industry standards that you can enable instantly to evaluate against common security policies without custom configuration.

🔍 Find security requirements by name or description

< 1 2 >

☐	Security requirement name ▲	Status ▼	Description ▼
☐	Audit Logging Best Practices	✔️ Enabled	Ensure the system supports security monitoring.
☐	Authentication Best Practices	✔️ Enabled	Ensure only legitimate users can access the system.
☐	Authorization Best Practices	✔️ Enabled	Ensure systems follow authorization best practices.
☐	Information Protection Best Practices	✔️ Enabled	Ensure sensitive data remains confidential and unaltered.
☐	Log Protection Best Practices	✔️ Enabled	Protect the integrity and confidentiality of system logs.
☐	Privileged Access Best Practices	✔️ Enabled	Ensure there are adequate guardrails for privileged functions.
☐	Rate Limiting Best Practices	✔️ Enabled	Prevent excessive usage of system capabilities.
☐	Secret Protection Best Practices	✔️ Enabled	Ensure that secrets like credentials remain confidential.
☐	Secure by Default Best Practices	✔️ Enabled	Ensure the system's default configuration is secure.
☐	Tenant Isolation Best Practices	✔️ Enabled	Ensure appropriate separation between system tenants.

- AWS Security Agent <
- Agent spaces

Security requirements

Integrations

Settings

Security requirements [Info](#)

Security requirements are used by AWS Security Agent to analyze compliance in design review and code reviews. Choose from AWS-managed requirements or create custom ones tailored to your standards.

- Managed security requirements
- Custom security requirements
- Enabled security requirements

Custom security requirements (3)					
		Actions		Create custom security requirement	
☐	Security requirement name	Security requirement status	Security Requirement Description	Date created	Date Modified
☐	Customer-Managed Encryption Keys Required	Enabled	The design must specify the use of customer-managed KMS keys (CMK) rather than AWS-managed keys for encrypting sensitive data at rest. Customer-managed keys provide granular control over key policies, rotation schedules, and access logging that AWS-managed keys cannot provide.	November 14, 2025 at 21:57 (UTC-08)	November 14, 2025 at 21:57 (UTC-08)
☐	Network Segmentation Strategy Defined	Enabled	The design must define a clear network segmentation strategy that separates workload components into logical layers based on data sensitivity, access requirements, and component behavior.	November 14, 2025 at 22:00 (UTC-08)	November 14, 2025 at 22:20 (UTC-08)
☐	Short Session Timeouts for Privileged and PII Access	Enabled	The design must specify short session timeout durations for administrative access, privileged operations, and access to customer personally identifiable information (PII).	November 14, 2025 at 22:13 (UTC-08)	November 14, 2025 at 22:13 (UTC-08)

AWS Security Agent <

Agent spaces

[AcmeCorp- Scheduling app](#)

Security requirements

Integrations

Settings

Launch web application 

AcmeCorp- Scheduling app [Info](#)

[Actions](#) ▾ [Launch web application](#)

Design review
 **Ready**
Evaluate system designs against your security requirements and best practices. [View security requirements](#) for your organization.
[Start in web app](#)

Code review
 **Needs setup**
Automatically review pull requests for security vulnerabilities and compliance with your organization's security requirements.
[Enable code review](#)

Penetration testing
 **Needs setup**
Automatically discover, verify and remediate security vulnerabilities through on demand penetration testing
[Enable penetration test](#)

- [Web app](#)
- [Design review](#)
- [Code review](#)
- [Penetration test](#)

Web app access

Admin access
Access the web app without IAM Identity Center user assignment.
[Admin access](#) 
Admin access sessions are limited to a maximum of 30 minutes.

User access
User access to the web app is managed by IAM Identity Center.
Agent web app URL

Users (1)  [Delete users](#) [Add users](#)

Username

Email

Details

Review status

✔ Completed

Date completed

12/2/2025, 8:33:16 AM

Files reviewed

1 uploads

Findings summary

2

✖ Non-compliant

Security requirements are violated or not adequately addressed.

0

⚠ Insufficient data

A security requirement's relevance criteria indicate it doesn't apply to this system design.

1

✔ Compliant

Security requirements are met based on the uploaded files.

0

⊖ Not applicable

The uploaded files don't contain enough information.

Files reviewed (1)

Download original

Search for file

File name	Type	Size
High level design sample design security review	PDF	137.53 KB

Review findings (3)

Select a finding below to view more details and suggested remediation guidance.

Search by security requirement

Filter security requirements by name

Filter by compliance status

View all

Finding by security requirement	Status
<u>Short Session Timeouts for Privileged and PII Access</u>	✖ Non-compliant
<u>Customer-Managed Encryption Keys Required</u>	✖ Non-compliant
<u>Network Segmentation Strategy Defined</u>	✔ Compliant

AWS Security Agent

Agent spaces

AcmeCorp- Scheduling app

Security requirements

Integrations

Settings

Launch web application

 Integration resources added



AcmeCorp- Scheduling app

Info

Actions

Launch web application

Design review

 Ready

Evaluate system designs against your security requirements and best practices. [View security requirements](#) for your organization.

Start in web app

Code review

 Ready

Automatically review pull requests for security vulnerabilities and compliance with your organization's security requirements.

View github repos

Penetration testing

 Needs setup

Automatically discover, verify and remediate security vulnerabilities through on demand penetration testing

Enable penetration test

Web app

Design review

Code review

Penetration test

GitHub

 AcmeCorpSchedulingApp (7)

Remove

Edit

Add

☐

Repository

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐

☐



Setup penetration test

Setup your Agent Space configuration including target domains, VPCs, security groups, subnets, CloudWatch log groups, S3 resources, GitHub repos, and access roles for your penetration testing environment.

▼ Add and verify target domains [Info](#)

Specify domains from Route53 or enter custom domains. After setup, select the verification method to confirm domain ownership for penetration testing in the penetration testing tab.

Domain

Verification method

[Remove](#)

[Add new domain](#)

You can add up to 4 more domains.

▼ VPC – Optional

Select a VPC and its related subnets and security groups to define the network scope for your penetration test.

VPC

Security group

Subnets

[Remove](#)

[Add another VPC](#)

You can add up to 4 more VPCs.

▼ CloudWatch configuration

Configure CloudWatch log groups to capture and analyze application behavior during security testing. If you don't select any log group, we'll create one for you during penetration test.

CloudWatch group

Select one or more CloudWatch groups from AWS account.



▼ Secrets – Optional

Select one or more secrets from AWS Secrets Manager in your AWS account.

Secrets

Select one or more secrets from AWS Secrets Manager in your AWS account.

▼ Lambda functions – Optional

Select one or more Lambda functions from your AWS account.

{Penetration test name}

Target URLs: 3 URLs Created: Nov 12, 2025 10:02 AM (UTC - 8:00)

Modify penetration test details

Run penetration test

Penetration test runs

Penetration test configurations

Penetration test learning resources

Latest run

View Run

Start time Nov 21, 2025 11:57 AM (UTC - 8:00)	Status In progress	Duration 19 minutes 2 seconds	ID [REDACTED]
Current step/ milestones Penetration test			
Vulnerability findings so far ● Critical: 2 ● High: 0 ● Medium: 1 ● Low: 0			

All runs (6)

Find runs

< 1 2 3 4 5 >

Run time	Status	Duration	Findings summary	ID
Nov 21, 2025 11:57 AM (UTC - 8:00)	In progress	19 minutes 2 sec...	● Critical: 2 ● High: 0 ● Medium: 1 ● Low: 0	[REDACTED]
Nov 21, 2025 08:24 AM (UTC - 8:00)	Complete	2 hours 33minutes...	● Critical: 4 ● High: 5 ● Medium: 2 ● Low: 0	[REDACTED]
Nov 20, 2025 4:42 PM (UTC - 8:00)	Complete	3 hours 13minutes...	● Critical: 5 ● High: 1 ● Medium: 3 ● Low: 0	[REDACTED]
Nov 20, 2025 09:56 AM (UTC - 8:00)	Complete	2 hours 41minutes...	● Critical: 7 ● High: 2 ● Medium: 3 ● Low: 0	[REDACTED]
Nov 19, 2025 11:40 AM (UTC - 8:00)	Complete	2 hours 24minutes...	● Critical: 7 ● High: 2 ● Medium: 4 ● Low: 0	[REDACTED]
Nov 18, 2025 11:45 AM (UTC - 8:00)	Complete	2 hours 33minutes...	● Critical: 7 ● High: 2 ● Medium: 4 ● Low: 0	[REDACTED]



11/13/2025 pentest job

↳ Pentest: [Pentest name](#) Created: 09/12/2025 at 11:39:23 Duration: 09/12/2025 at 11:39:23

✔

Complete

Preflight

✔

Complete

Static analysis

✔

Complete

Penetration test

✔

Complete

Finalizing

Penetration test run overview

Penetration test logs

Findings

Findings

The findings will be discovered and validated by AWS Security Agent as penetration test run progresses.

🔍 Search findings

SSRF via X-Forwarded-Host Header Injection in CloudFront Distribution

Confidence high

Critical

Last updated: 11/13/2025 03:24:06

The CloudFront distribution at [redacted] is vulnerable to Server-Side Request...

Sub Resource Integrity (SRI) Attribute Missing on External Script

Confidence high

Informational

Last updated: 11/13/2025 01:51:59

The web application loads an external JavaScript file from a CDN [redacted] ...

AWS Cognito OAuth2 PKCE Not Enforced - Security Configuration Weakness

False positive

Informational

Last updated: 11/13/2025 01:50:44

The AWS Cognito OAuth2 authorization endpoint [redacted]

Information disclosure

False positive

Informational

Last updated: 11/13/2025 01:50:44

The AWS Cognito OAuth2 authorization endpoint [redacted]

SSRF via X-Forwarded-Host Header Injection in CloudFront Distribution

Mark as resolved

Remediate finding

Was this finding accurate?

👍 Yes

👎 No

▶ Note on this finding - Optional

Agent confidence

Confidence high

Severity

Critical

Finding logs

[Trace logs](#)

Risk type

Server-Side Request Forgery (SSRF)

▼ Description

The CloudFront distribution at [redacted] is vulnerable to Server-Side Request Forgery (SSRF) through X-Forwarded-Host header injection. When an attacker provides a malicious X-Forwarded-Host header, the backend origin server makes an outbound request to the attacker-controlled domain. This vulnerability allows attackers to force the backend to make requests to internal services, potentially access cloud metadata services (169.254.169.254), expose internal AWS resources, perform port scanning of internal networks, and may lead to data exfiltration from internal services. The CloudFront distribution improperly passes the X-Forwarded-Host header to the backend without validation or sanitization, causing the origin server to trust and act upon client-supplied header values.

▼ Attack reasoning

• Attack Vector (AV): **Network**

- The vulnerability can be exploited remotely over the network via HTTP requests to the CloudFront distribution without requiring any physical or local access

• Attack Complexity (AC): **Low**

- The attack is straightforward requiring only the injection of a single HTTP header (X-Forwarded-Host) with no timing dependencies, specialized configurations, or complex setup needed.

• Privileges Required (PR): **None**

- No authentication or privileges are required; any anonymous user can send the malicious request to the public CloudFront endpoint.

• Scope (S): **Changed**

- The vulnerability allows the attacker to affect resources beyond the vulnerable CloudFront component, specifically enabling requests to internal AWS services, metadata endpoints (169.254.169.254), and internal network resources that the origin server can access

• Confidentiality Impact (C): **High**

- The SSRF can be leveraged to read sensitive data from internal services, access cloud metadata containing IAM credentials, and exfiltrate information from backend systems that should not be publicly accessible.

• Integrity Impact (I): **Low** -

- While the SSRF primarily enables reading data, there is limited potential to modify data through internal API calls if the accessed services accept state-changing operations via GET requests or if the attacker can chain this with other vulnerabilities.

• Availability Impact (A): **None** -

- The SSRF vulnerability itself does not directly cause denial of service or affect the availability of the CloudFront distribution or backend services under normal exploitation scenarios.

▼ Steps to reproduce

Proof of Concept:

1.Send a request with X-Forwarded-Host header to the CloudFront distribution:

- curl -H [redacted]

2. Response: HTTP 200 OK

3. Verification: The SSRF endpoint [redacted] confirmed that the backend origin server made a DNS lookup and/or HTTP request to the attacker-controlled domain. The vulnerability was confirmed by calling verify_ssrf_exploit tool which validated that the target application successfully sent a request to the SSRF detection endpoint, proving that the backend processes and acts upon the X-Forwarded-Host header value supplied by the client. This demonstrates that an unauthenticated attacker can manipulate the backend server into making arbitrary requests to any domain or IP address they specify in the X-Forwarded-Host header.

aws

© 2025, Amazon.com, Inc. or its affiliates. All rights reserved.

Blogpost:

New AWS Security Agent secures applications proactively from design to deployment (preview)



<https://aws.amazon.com/blogs/aws/new-aws-security-agent-secures-applications-proactively-from-design-to-deployment-preview/>



© 2025, Amazon Web Services, Inc. or its affiliates. All rights reserved.

AWS Security Incident Response AI investigative agent

AI-POWERED EVIDENCE GATHERING AND ANALYSIS FOR FASTER INCIDENT RESPONSE



- ✓ Reduces the time required to investigate security events from hours to minutes
- ✓ Automatically gathers and correlates evidence across multiple AWS data sources
- ✓ Builds a comprehensive timeline of events and presents findings in clear, actionable summaries
- ✓ Backed by the expertise and oversight of the AWS security experts

This response was generated using AWS Generative AI capabilities. You are responsible for evaluating any recommendations in your specific context and implementing appropriate oversight and safeguards. Learn more about [AWS Responsible AI requirements](#). For details on managing AI-generated recommendations in case management, see the [AWS Security Incident Response documentation](#).

1234567890

2 hours ago

Investigation Summary

This investigation examined suspicious activity reported for AWS account 111122223333 involving access key AKIAIOSFODNN7EXAMPLE. The investigation centered on unusual S3 reconnaissance operations that occurred approximately 72 minutes after the access key was created during an automated infrastructure provisioning process on October 24, 2025.

Critical Findings

Credential Exposure Pattern

- IAM user `analytics-data-engineer` and access key AKIAIOSFODNN7EXAMPLE were created at 15:06:42 UTC by admin user `mary_major` during automated provisioning
- The same access key was used from IP 203.0.113.10 starting at 16:18:48 UTC (72 minutes later) with indicators suggesting potential unauthorized access
- User agent identified as `aws-cli/2.23.6` on Kali Linux distribution (penetration testing platform)

Observed Activity (October 24, 2025, 16:18:45 - 17:22:02 UTC)

- Successfully enumerated all S3 buckets in the account via `ListBuckets`
- Inspected bucket policies on three sensitive buckets containing customer analytics, financial reporting, and HR records
- Attempted to create bucket named "amzn-s3-demo-bucket" - **denied due to insufficient permissions**
- No evidence of successful data access (`GetObject` calls) found in available CloudTrail logs
- Activity confined to us-east-1 region with no subsequent use of the access key detected

Affected Resources

- IAM User: `analytics-data-engineer` (arn:aws:iam::111122223333:user/engineering/analytics-data-engineer)
- Access Key: AKIAIOSFODNN7EXAMPLE
- S3 Buckets examined: `corp-customer-analytics-prod-111122223333`, `finance-reporting-data-prod-111122223333`, `hr-employee-records-prod-111122223333`
- Source IP: 203.0.113.10

Limiting Factors

- The attached `AnalyticsDataAccessPolicy` granted broad S3 read permissions but lacked `s3:CreateBucket`, preventing the staging bucket creation
- No `s3:PutObject` or `s3:PutBucketPolicy` permissions prevented further escalation
- Activity remained limited to reconnaissance operations

▼ Technical Findings

Timeline of Relevant Events

October 24, 2025 - 15:06:42 UTC: Infrastructure Provisioning

- User: `mary_major` (Admin role session)
- Source IP: 10.24.34.15 (AWS internal range)
- User Agent: Boto3/Python on macOS
- Actions performed:
 - Created IAM user `analytics-data-engineer` in `/engineering/` path
 - Generated access key `AKIAIOSFODNN7EXAMPLE`
 - Attached policy `AnalyticsDataAccessPolicy` with broad S3 read permissions
 - Created 3 S3 buckets with disabled public access blocks:
 - `corp-customer-analytics-prod-111122223333`
 - `finance-reporting-data-prod-111122223333`
 - `hr-employee-records-prod-111122223333`

October 24, 2025 - 16:18:48 UTC: Unusual Activity Begins

- User: `analytics-data-engineer` (access key `AKIAIOSFODNN7EXAMPLE`)
- Source IP: 203.0.113.10
- User Agent: `aws-cli/2.23.6` on `linux#6.16.8+kali-cloud-amd64 md/distrib#kali.2025`
- Sequence of API calls:
 1. `GetCallerIdentity` - identity verification
 2. `ListBuckets` - discovered all account S3 buckets
 3. `GetBucketPolicy` on three recently-created buckets (`corp-customer-analytics`, `finance-reporting-data`, `hr-employee-records`)
 4. `CreateBucket` for "amzn-s3-demo-bucket" - **denied due to insufficient permissions**
 5. Additional `ListBuckets` and `GetCallerIdentity` calls
 6. Final activity at 17:22:02 UTC

Blogpost:

Accelerate investigations with AWS Security Incident Response AI- powered capabilities



<https://aws.amazon.com/blogs/security/accelerate-investigations-with-aws-security-incident-response-ai-powered-capabilities/>



© 2025, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Amazon Bedrock AgentCore adds quality **evaluations** and **policy** controls for deploying trusted AI agents (Preview)

BUILDING TRUSTED, PRODUCTION-READY AI AGENTS AT SCALE



Deploy Trusted Agents at Scale

New governance and quality capabilities remove production barriers (2M+ SDK downloads, proven results: 1,000% speed increase, 50% faster resolution)

Control & Quality

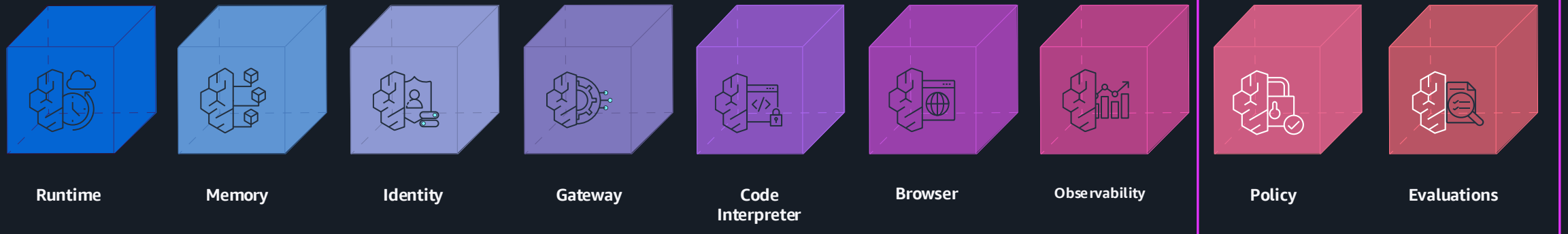
Builds a comprehensive timeline of events and presents findings in clear, actionable summaries

Enhanced Agent Capabilities

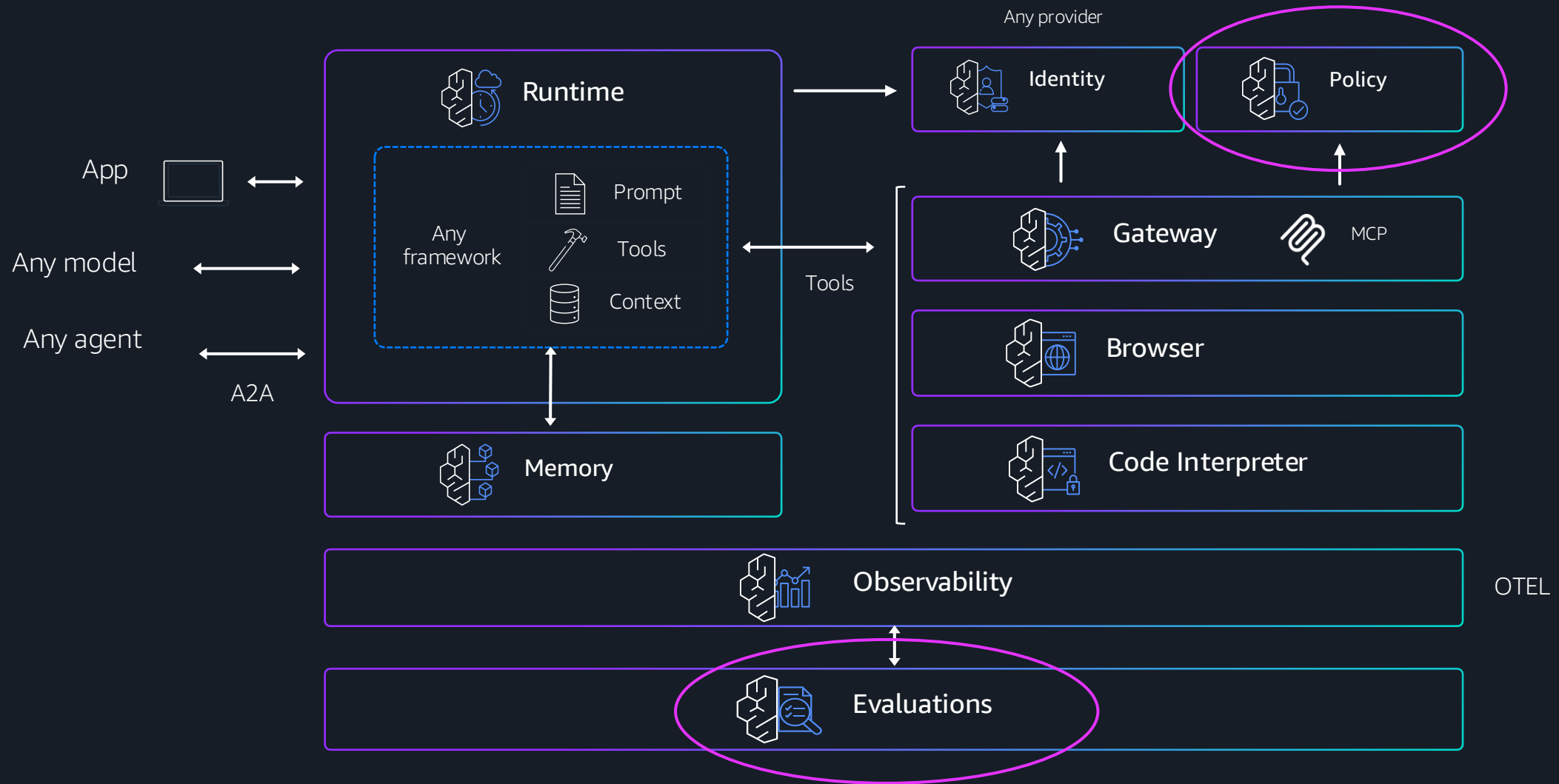
Episodic memory enables learning from experience; bidirectional streaming powers natural voice conversations with real-time interruption handling

Amazon Bedrock AgentCore Evaluations and Policy

Comprehensive agentic platform: Everything you need for getting agents into production



Amazon Bedrock AgentCore Platform



Identity



Identity launches

SECURELY MANAGE ACCESS FOR YOUR CUSTOMERS, WORKFORCE, AND WORKLOADS



AWS IAM Policy Autopilot: An MCP Server that helps customers and their coding assistants' author, manage, and troubleshoot their AWS IAM policies without having to become AWS IAM experts



STS Outbound Federation: New capability in AWS Security Token Service (STS) that enables customers to obtain standards-based JSON Web Tokens (JWTs) for their AWS workloads to federate outside the AWS identity realm



Temporary delegation is available to select ISV Partners: A new IAM capability that lets customer can delegate the setup of ISV partner product in their AWS environment to the partner SaaS control plane



Login for AWS local development: A new capability that lets developers use their existing AWS Management Console sign-in credentials for programmatic access to AWS services through a new 'aws login' CLI command

AWS IAM Policy Autopilot

ENABLE YOUR AI CODING ASSISTANTS TO QUICKLY CREATE BASELINE IAM POLICIES



Faster development

Skip manual IAM research and get functional permissions



Reliable and valid policies

Deterministic code analysis ensures accurate IAM actions



Coding assistant ready

Works with Kiro, Claude Code, Cursor, other MCP-enabled tools

IAM Policy Autopilot

An open source Model Context Protocol (MCP) server and command-line tool that helps your AI coding assistants quickly create baseline IAM policies that you can refine as your application evolves, so you can build faster. IAM Policy Autopilot analyzes your application code locally to generate identity-based policies for application roles, enabling faster IAM policy creation and reducing access troubleshooting time. IAM Policy Autopilot supports applications built in Python, Go, and TypeScript.

Table of Contents

- [Who is IAM Policy Autopilot for?](#)
- [How is IAM Policy Autopilot helpful?](#)
- [Best Practices and Considerations](#)
- [Getting Started](#)
- [CLI Usage](#)
- [Build Instructions](#)
- [Workspace Structure](#)
- [Development](#)
- [Security](#)
- [License](#)

Who is IAM Policy Autopilot for?

IAM Policy Autopilot is for builders on AWS using AI coding assistants, including developers, product managers, technical experimenters, and business leaders.



AWS IAM Outbound Identity Federation

SIMPLIFY ACCESS TO EXTERNAL SERVICES WITHOUT LONG-TERM CREDENTIALS

Replace Long-Term Credentials with Short-Lived JWTs

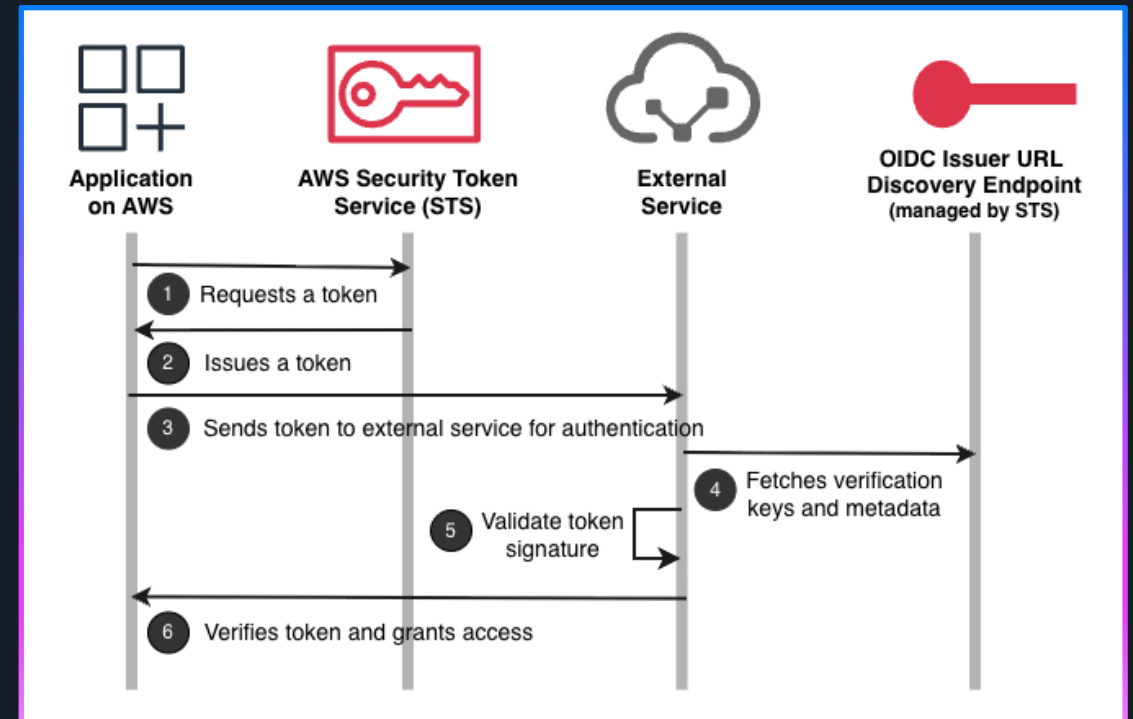
Securely authenticate AWS workloads with external services using cryptographically signed tokens (60 seconds to 1 hour lifetime) instead of storing API keys and passwords

Automated Token Verification Flow

Call AWS STS GetWebIdentityToken API to receive JWTs; external services verify signatures using public JWKS endpoints with support for ES384 and RS256 signing algorithms

Policy-Based Governance & Universal Availability

Control token generation with IAM policies and condition keys for audiences, algorithms, and lifetimes; available at no cost in all AWS Regions including GovCloud and China



AWS IAM temporary delegation for select ISPs

ACCELERATE ONBOARDING AND SIMPLIFY MANAGEMENT FOR 1P AND 3P SERVICES



Guided experience

Customized to partner product workflow and interface



Limited Access

Grant time-limited privileged access



Governance

Optional admin approval for elevated access



© 2025, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Amazon Web Services | IAM AWS Partner account access request

us-east-2.signin.aws.amazon.com/oauth?client_id=arn%3Aaws%3Asignin%3A%3A%3Aconsole%2Fcanvas&code_ch...

Account ID: 1111-2222-3333 ▼
Admin/zekewan-isengard

Allow [AnyCompany] temporary access to your AWS account?

Allow AnyCompany to use your AWS identity to complete actions on your behalf.

AWS Partner identifier 999988887777	Requested access duration 120 minutes
---	---

Request message

AnyCompany.com is requesting temporary access your AWS account to configure the external storage feature on your behalf.

Additional information: [optional] AWS error when using your AWS principal zekewan/admin-11112222333 when deploying resources: Access denied

AWS permissions AnyCompany can access [View JSON](#)

Permissions summary | ✨ Generated by AI

Generating a response

✔ Permission simulation: AWS Partner actions are likely to succeed if allowed using your current AWS identity. [Learn more](#)

[Deny access](#) [Request approval](#) [Allow access](#)

Simplified developer access to AWS with 'aws login'

START BUILDING WITH YOUR EXISTING CREDENTIALS, NO LONG-TERM ACCESS KEYS REQUIRED



Enhanced Security

No long-term credentials needed, temporary tokens expire automatically



Faster onboarding

Browser-based login eliminates manual access-key creation and management



Universal compatibility

Works seamlessly with AWS CLI, SDKs, and third-party developer tools

Sign in to AWS

Continue with an active session

By continuing, you allow AWS CLI, SDKs, and local developer tools to use your credentials until your session expires.

1234-5678-1234

testadminrole

Logged in 12 minutes ago

1234-5678-1234

Audit-Role

Logged in 9 minutes ago

1234-5678-1234

ReadOnly-Role

Logged in 9 minutes ago

OR

Sign into new session

Detection and Response



Detection and Response launches

DETECT, PRIORITIZE, AND RESPOND TO CRITICAL SECURITY ISSUES



AWS Security Hub: Tier 1 launch that features new AI-powered security capabilities that will provide customers a single place to combine signals from multiple services to calculate, prioritize, and address their most critical security issues



AWS Security Hub simplified pricing: one bill for all your integrated services, resource-based pricing that grows with you, no double charging, and a cost estimator built right in to help you plan your budget.



Amazon GuardDuty Malware Protection for S3 – On-demand: Provides on-demand malware scanning for objects in S3 buckets



Amazon GuardDuty Malware Protection for AWS Backup: Native scanning for malware for AWS Backup for S3 and EBS



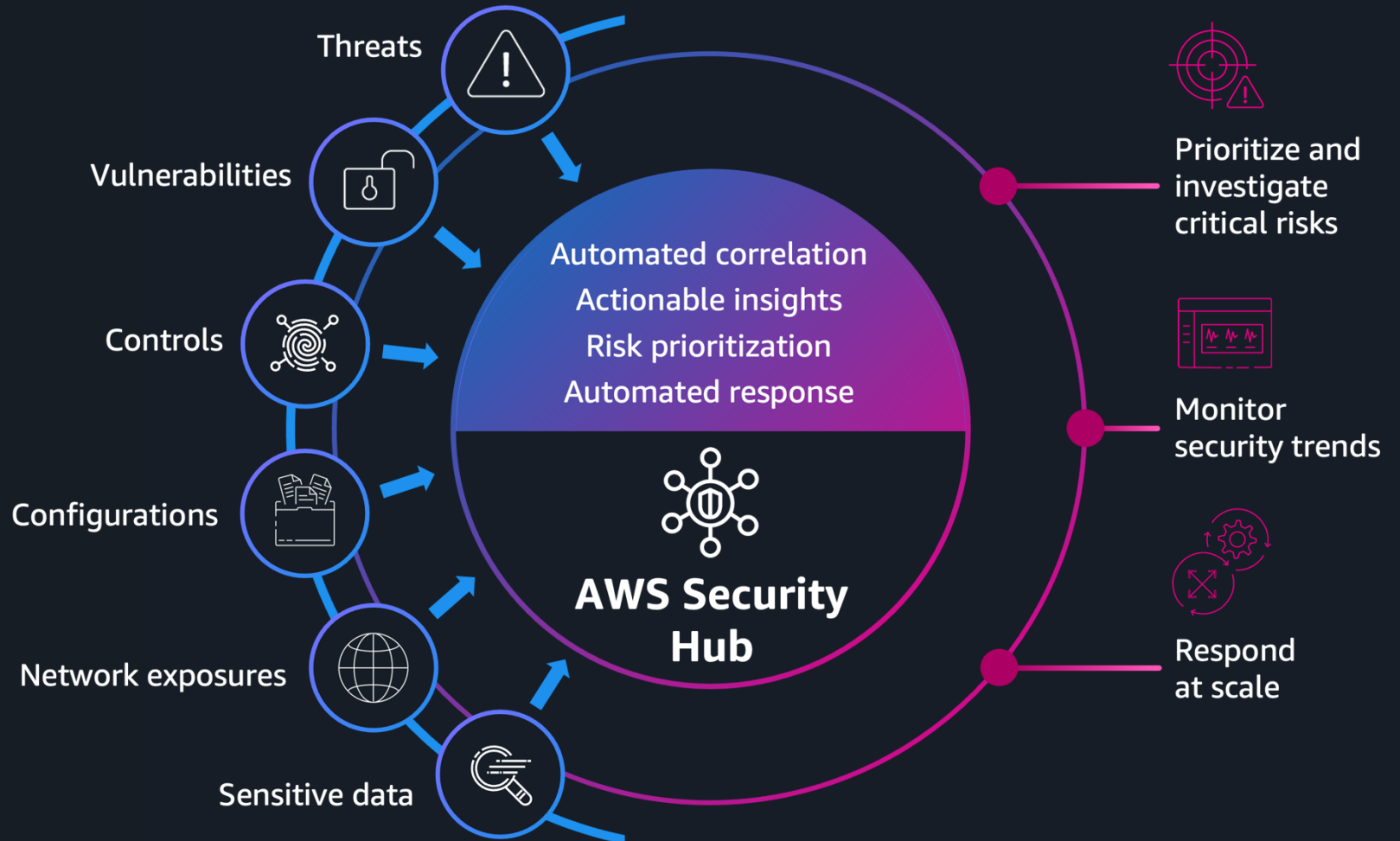
Amazon EC2 & ECS XTD: Amazon GuardDuty expanding attack sequence findings to cover EC2 and ECS

AWS Security Hub

PRIORITIZE YOUR MOST CRITICAL SECURITY ISSUES AND RESPOND AT SCALE

Unified cloud security solution

- ✓ Prioritizes your critical security issues and helps you respond at scale to reduce security risks, improve team productivity, with near real-time risk analytics and advanced trends
- ✓ Combines signals from services such as Security Hub CSPM, Inspector, and more
- ✓ Calculates overall security risk, prioritize those risks, and help customers address their most critical security issues



AWS Security Hub simplified pricing and cost estimation

BEFORE

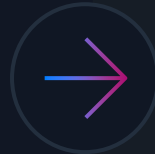
Multiple complex bills

GuardDuty bill

Inspector bill

Security Hub CSPM bill

- ✗ Multiple invoices
- ✗ Unpredictable costs
- ✗ Manual cost estimation



NOW

One simplified bill

Security Hub bill

- ✓ Single invoice
- ✓ Predictable costs
- ✓ Built-in cost estimator

Amazon GuardDuty

Foundational data sources



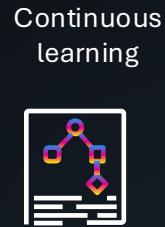
VPC Flow Logs, DNS logs
CloudTrail events involving
AWS IAM access keys
and Amazon EC2

AWS workload protection sources



- Amazon S3 data plane events
- Amazon EKS audit logs
- Amazon Aurora login events
- AWS Lambda network activity
- Runtime activity

Security analytics



Security findings

Actionable
Accurate
Contextual

Extended Threat Detection



AI/ML enhanced
attack sequence

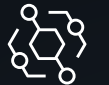
Integration and Remediation



Amazon
Detective



AWS
Security Hub



Amazon
EventBridge



Malware scanning

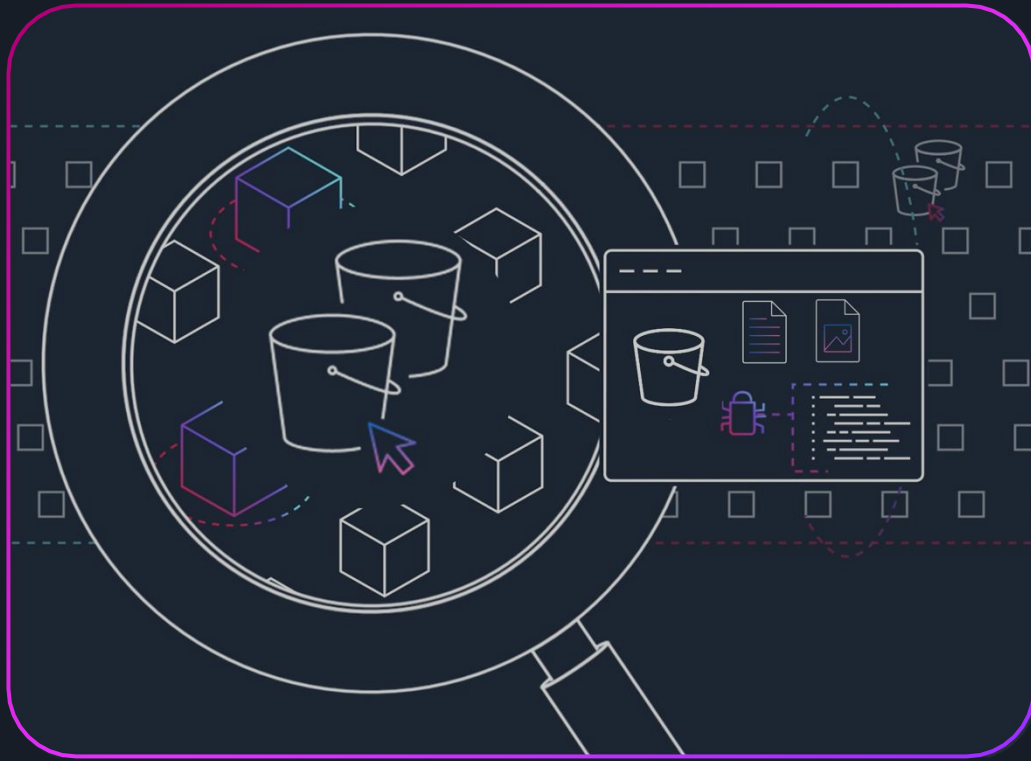


- EBS data volumes attached to Amazon EC2 instances and container workloads
- Amazon S3 objects
- Backup data - Amazon EC2, Amazon EBS, and Amazon S3



Amazon GuardDuty Malware Protection for S3 – On-Demand

USE ON-DEMAND API TO SCAN EXISTING S3 OBJECTS



- ✓ Scan **existing S3 objects selectively on-demand** for malware using API
- ✓ Detect, tag, and **quarantine malware**
- ✓ **Seamless integration** into existing workflows to secure S3 data pipelines
- ✓ **Minimal configuration** for application developers and security team

Amazon GuardDuty Malware Protection for S3 – On-Demand

USE ON-DEMAND API TO SCAN EXISTING S3 OBJECTS

```
aws guardduty send-object-malware-scan  
  --s3-object '{"Bucket": "amzn-s3-demo-bucket", "Key": "APKAEIBAERJR2EXAMPLE"}'
```



Amazon GuardDuty Malware Protection for AWS Backup

ENSURE CLEAN BACKUPS FOR FASTER, CONFIDENT RECOVERY



- ✓ Detect malware in Amazon EC2, Amazon EBS, and Amazon S3 backups without deploying additional security software or agents.
- ✓ Automatically scan backups after creation and run on-demand scans of past backups with cost-effective incremental scanning.
- ✓ Verify backup integrity before restoration through fully managed protection that integrates seamlessly with AWS Backup.

GuardDuty

Summary

Findings

Malware scans

▼ Protection plans

S3 Protection

EKS Protection

Extended Threat Detection New

Malware scans (0) Info

Monitor the scan status of the GuardDuty-Initiated, Backup-Initiated, or on-demand scans.

Q Search Scan ID, Account ID, or add filter criteria

< 1 >

Scan ID	Resource	Resource type	Scan type	Status	Scan result	Start time
No malware scans						
No malware scans to display						
Start on-demand scan						



Scan configurations

Scan scope

☐ On-demand malware scans for EC2 instance
Detect malware by scanning Amazon EBS volumes that are attached to Amazon EC2 instances and container workloads running on Amazon EC2.

☒ Scan backup of an AWS resource - new
Initiate an on-demand full or incremental malware scans to detect the presence of malware on Amazon EC2, EBS or S3 backups in your account.

Scan mode

☐ Incremental scan
Scan incremental data changes between previous and current backup AWS resource to detect for potential malware.

☒ Full scan
Scan entire data of an AWS backup resource to detect the potential presence of malware.

Resource ARN

Enter the ARN of the AWS resource backup you want to scan for potential malware.

Enter Resource ARN

Must be in format arn:aws:\${Vendor}:us-east-1:\${Account}:\${ResourceType}/\${ResourceId} or arn:aws:backup:us-east-1:\${Account}:recovery-point:\${ResourceId}

Service access

GuardDuty requires permissions to perform malware scan actions on your behalf.

Choose existing service role

Choose an IAM role.

Required

View policy

Attach policy in IAM ↗

Cancel

Start scan



AWS Backup

My account

Dashboard

Jobs dashboard

Vaults

Backup vault locks

S3 backup tiering New

Backup plans

Protected resources

Search

Jobs

Malware protection New

Announcing New Features

- S3 Tiering** Automatically move S3 data to lower-cost storage based on the age of objects within a backup vault.
- Malware protection** Amazon GuardDuty Malware Protection for AWS Backup now supports malware scans of EC2, EBS and S3 backups.

Dashboard

With the dashboard, create scheduled or on-demand backups of

Backup plan

A Backup plan specifies the backup schedule, backup retention rules, and lifecycle rules for your backups.

Create backup plan

Malware protection - *new* [Info](#)

☒ **Enable malware scans** [See pricing](#) [↗](#)
Detect malware in your backups to prevent restoring infected data and improve your ability to recover quickly from attacks. [AWS Service Terms for GuardDuty Malware Protection](#) [↗](#) will apply.

Scanner

GuardDuty

Scanner role | [Info](#)

AWS Backup uses a scanner role to work with GuardDuty on your behalf. See **View policy** for the required permissions. Additionally, the IAM role in your backup selections must include scan permissions for scheduled scans to work properly.

AWSBackupGuardDutyRolePolicyForScansRole [↻](#)

[View policy](#) [Create IAM role](#) [↗](#)

Scannable resource types | [Info](#)

Select from the list of supported resource types.

Choose resource types ▼

☐ All supported resource types

☐ EBS

☐ EC2

☐ S3

Backup rules

DailyBackups

Scan mode

Incremental scan ▼

None

Full scan

Incremental scan ✓



Amazon GuardDuty Attack sequences findings on top threat scenarios

AI-POWERED DETECTION OF MULTISTAGE ATTACKS ACROSS EC2 AND ECS WORKLOADS



- ✓ Rapidly triage security alerts using attack sequence findings that automatically correlate individual signals to provide high-confidence insights for your Amazon EC2 instances and Amazon ECS clusters.
- ✓ Detect critical threats through automated analysis of network, runtime, malware, and API activity, identifying sophisticated attack patterns like crypto-mining and reverse shells.
- ✓ Streamline your response with detailed event timelines, MITRE ATT&CK® mappings, and prescriptive remediation recommendations based on AWS best practices.

Attack sequences findings on top threat scenarios

Compromised identity

IAM credentials used to make multiple suspicious requests that align with known attack behaviors, such as persistence, evasion, and workload creation

Compromised data

Sequence of actions suggesting compromise or exfiltration of data in one or more S3 buckets using potentially misused credentials

Compromised EKS clusters

Compromise of Kubernetes cluster or a container within it that can align with known attack behaviors such as privilege escalation and unauthorized access using compromised pod credentials

Compromised EC2 instances

Suspicious activities detected across EC2 instances indicating potential compromise through malicious processes, network communications, or unauthorized system modifications

Compromised ECS clusters

Anomalous container behavior within ECS clusters suggesting compromise through malicious task execution, unauthorized network activity, or container escape attempts

Launch
re:Inforce 2025

NEW

NEW



Data Protection



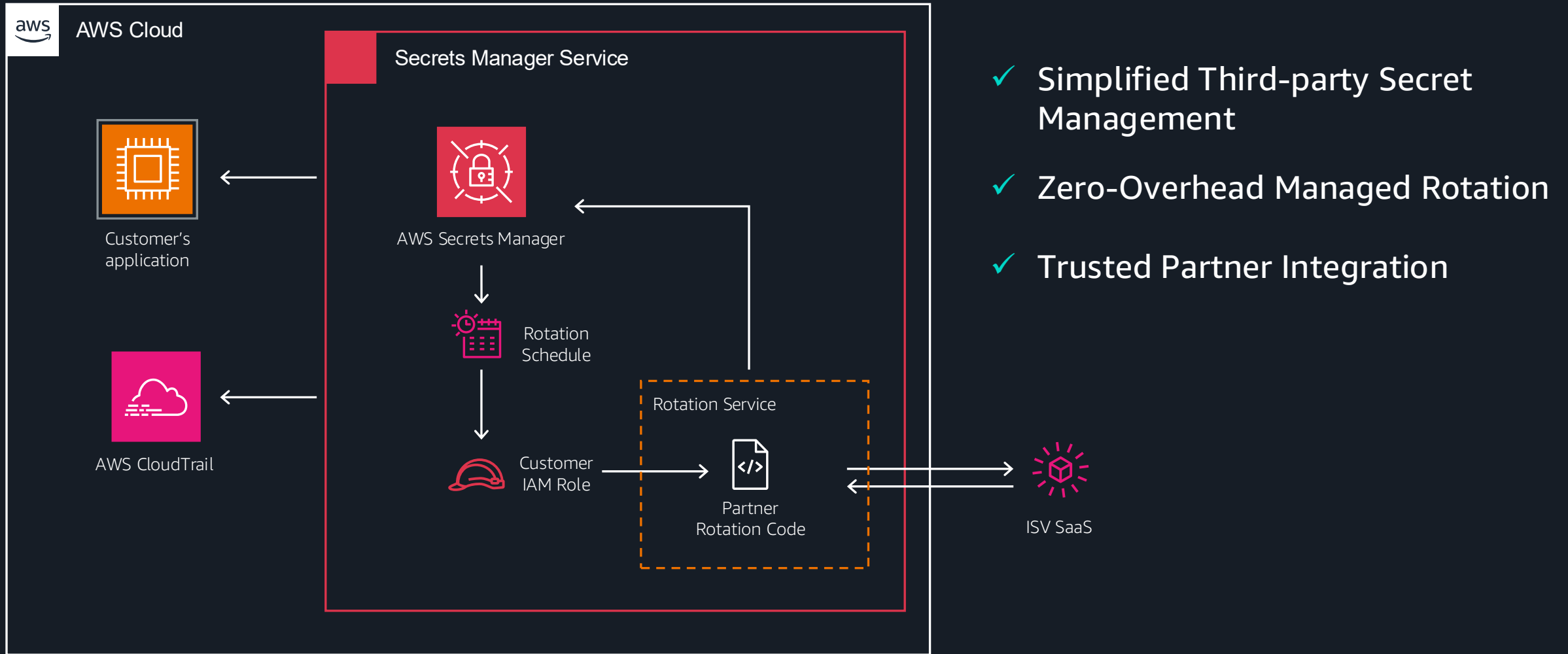
AWS Secrets Manager launches Managed External Secrets

SAFEGUARD CRITICAL INFORMATION ACROSS COMPLEX CLOUD DEPLOYMENTS



- ✓ Secures application credentials vended by third-party software providers in pre-defined and standardized formats
- ✓ Provides automated and managed secret rotation, eliminating need for custom rotation functions
- ✓ Allows centralized management of both AWS and third-party secrets from a single service at standard Secrets Manager pricing
- ✓ Offers security controls including IAM permissions, CloudWatch monitoring, CloudTrail logging, and GuardDuty threat detections

Managed external secrets



- ✓ Simplified Third-party Secret Management
- ✓ Zero-Overhead Managed Rotation
- ✓ Trusted Partner Integration

Network & Application Protection



Network & Application Protection launches

INGRAIN SECURITY IN YOUR NETWORK INFRASTRUCTURE AND SOFTWARE DEVELOPMENT



AWS Network Firewall Proxy: New explicit forward proxy feature, powered by AWS Network Firewall, to exert control and gain visibility into your internet traffic with the objective of preventing data leak



AWS Network Firewall Flexible Cost Allocation: Ability to track and allocate centralized NFW costs across internal business units



AWS Network Firewall Partner Managed Rules: Launch framework and support for deploying 3rd party threat intel based managed rules in Network Firewall



Amazon Route 53 DNS Firewall – DGA Attack Protection: Blocks queries associated with Dictionary-based Domain Generation Algorithm (DGA) attacks



Amazon CloudFront flat-rate pricing plans for Security: Bundles CloudFront, WAF, DDoS protection, Route 53 DNS FW, CloudWatch Logs, and serverless edge compute into one simple monthly price with no overage charges, plus S3 storage credits included



VPC Encryption Controls: Audit traffic flows in your environment and enforce encryption across all traffic within and across VPCs in a region



AWS Network Firewall Proxy (Preview)

APPLY EXPLICIT PROXY CONTROLS TO YOUR EGRESS TRAFFIC



Advanced Filtering and Security

DNS domain filtering, header/URL/IP filtering, anti-SNI spoofing, and content-type controls



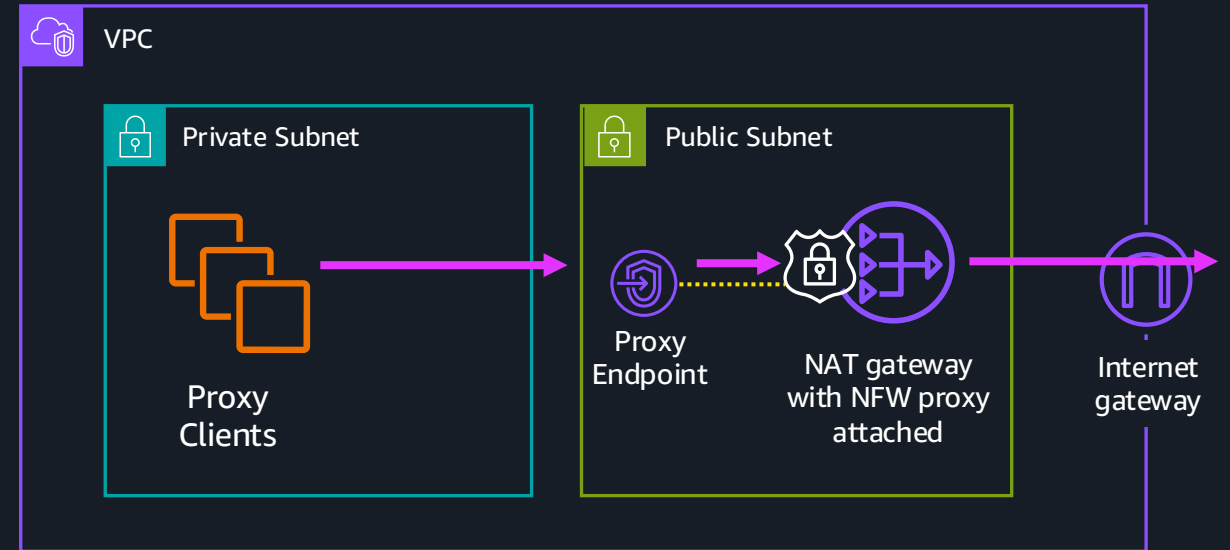
Easy Network Integration

Attaches to NAT Gateway with PrivateLink support for overlapping VPC CIDRs with Transit Gateway and Cloud WAN compatibility



Comprehensive Logging

Detailed tracking including VPC-ID, endpoint-ID, IP addresses, and expandable logging capabilities



Simple single VPC architecture example

- ✓ Explicit Proxy with independent DNS resolution
- ✓ HTTP/s Traffic
- ✓ Optional TLS Decryption

AWS Network Firewall Flexible Cost Allocation

ENABLE CHARGEBACK FOR TRANSIT GATEWAY AND NETWORK FIREWALL DATA PROCESSING COSTS



Solves the chargeback problem

Distribute Transit Gateway and Network Firewall data processing costs to the application teams generating the traffic—not just the central account



Accurate cost allocation

Divide growing data processing expenses among business units based on actual usage, regardless of deployment model (distributed VPCs or centralized TGW)

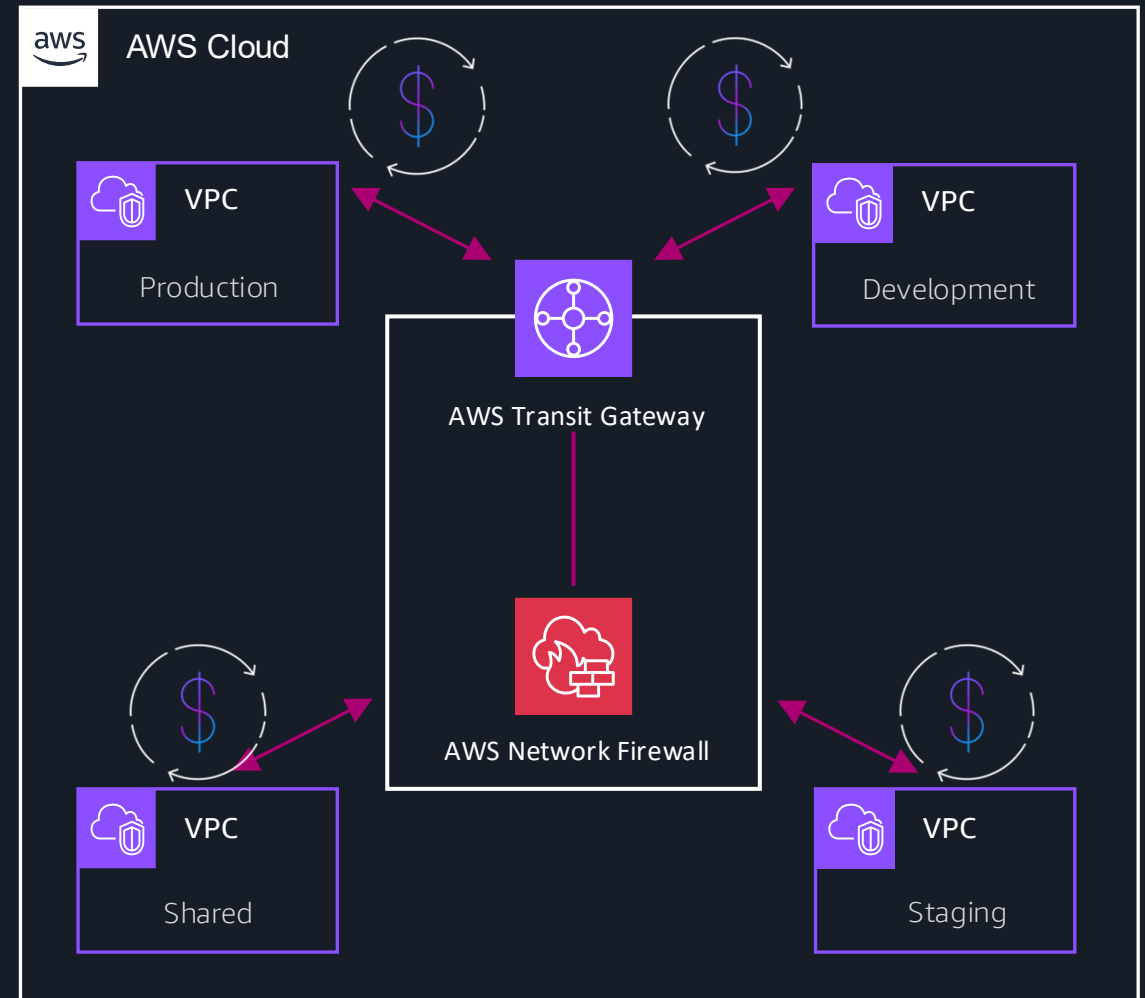


Better visibility and control

Gain clearer insights into security and networking expenses across complex architectures to optimize your most variable network costs



© 2025, Amazon Web Services, Inc. or its affiliates. All rights reserved.



Partner Managed Rules from AWS Marketplace for AWS Network Firewall

EXPERT-CURATED SECURITY RULES, ZERO MANAGEMENT BURDEN



Expert-curated rules from AWS Marketplace

Deploy pre-configured security rules from AWS Partners within AWS Network Firewall policies



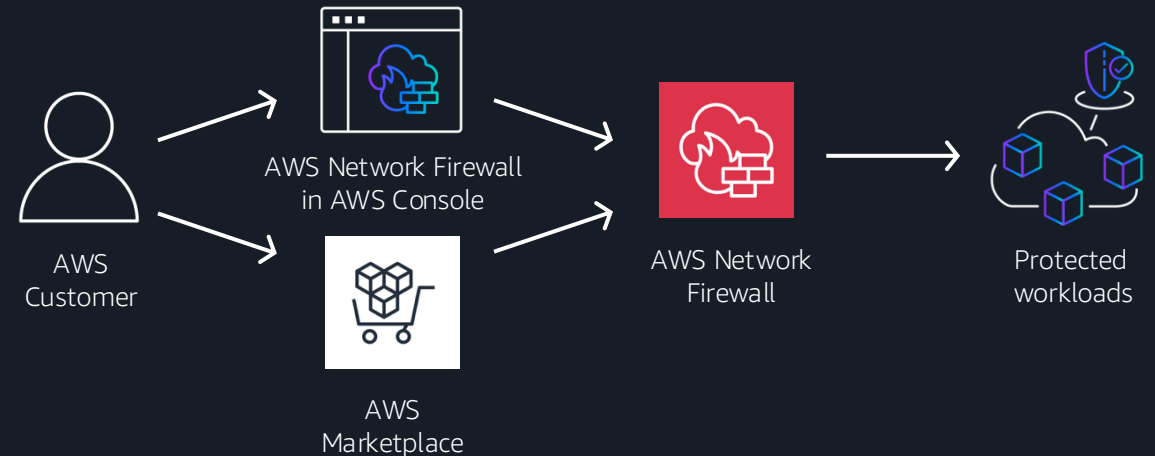
Automatic updates against emerging threats

Stay protected against emerging threats with automatically updated rule groups



Deploy in minutes, not days

Choose specialized protection tailored to your industry needs and compliance requirements



Threat **STOP**

infoblox

RAPID7

LUMEN

TREND MICRO

FORTINET

CHECK POINT

Amazon CloudFront flat-rate pricing plans for Security

SIMPLIFIED PRICING WITH A MONTHLY PRICE WITH NO OVERAGE CHARGES



Predictable monthly costs

Pay one flat price with transparency for CDN, WAF, DDoS protection, DNS, and storage – without overages or hidden fees



Simple plan selection

Choose plan tier based on features and configuration options, without complex calculations or spreadsheets



Scale with ease of mind

Handle attack traffic, viral content, and usage changes without worrying about unpredictable costs

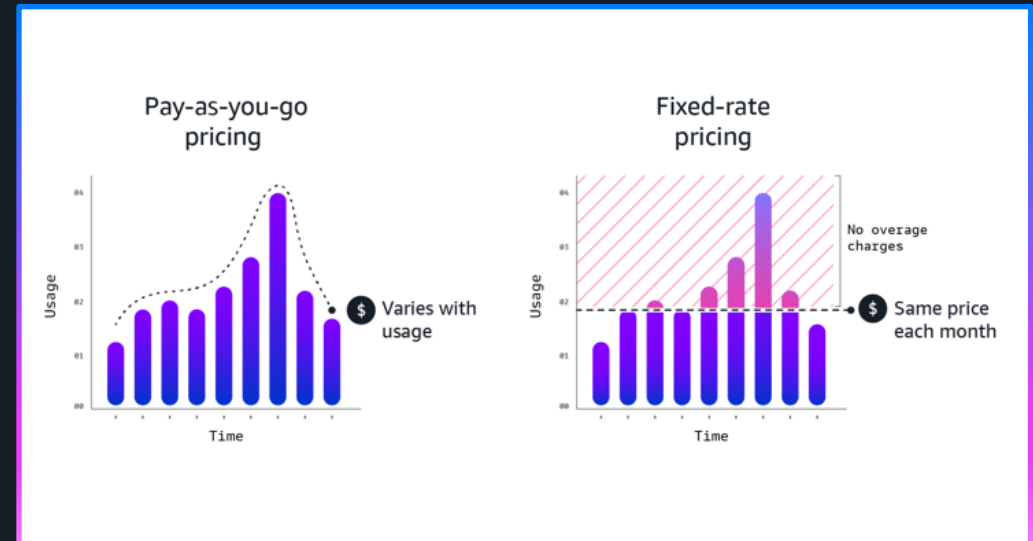


Everything included:

CDN (CloudFront), **WAF** (WAF), **DDoS** (Anti-DDoS AMR), **DNS** (Route 53), **Logging** (CloudWatch), **Storage credits** (S3)

How it works:

- Select the tier with the features and configurability your application needs.
- Pay the same published price, every month — regardless of usage.
- Plans are purchased per distribution / application



Introducing VPC encryption controls

ENFORCE ENCRYPTION IN TRANSIT WITHIN AND ACROSS VPCS IN A REGION



Audit & Enforce Encryption Compliance

Monitor mode provides encryption visibility via VPC flow logs; Enforce mode blocks unencrypted traffic and ensures encryption-compliant resource creation across VPCs and Transit Gateways



Automatic updates against emerging threats

Nitro System delivers automatic AES-256-GCM encryption with no performance penalty; supports HIPAA, PCI DSS, and FedRAMP compliance with centralized visibility and control



Automatic Service Migration

AWS transparently migrates Network Load Balancers, Application Load Balancers, and Fargate to encryption-compliant infrastructure; identify and update remaining resources before enabling enforce mode

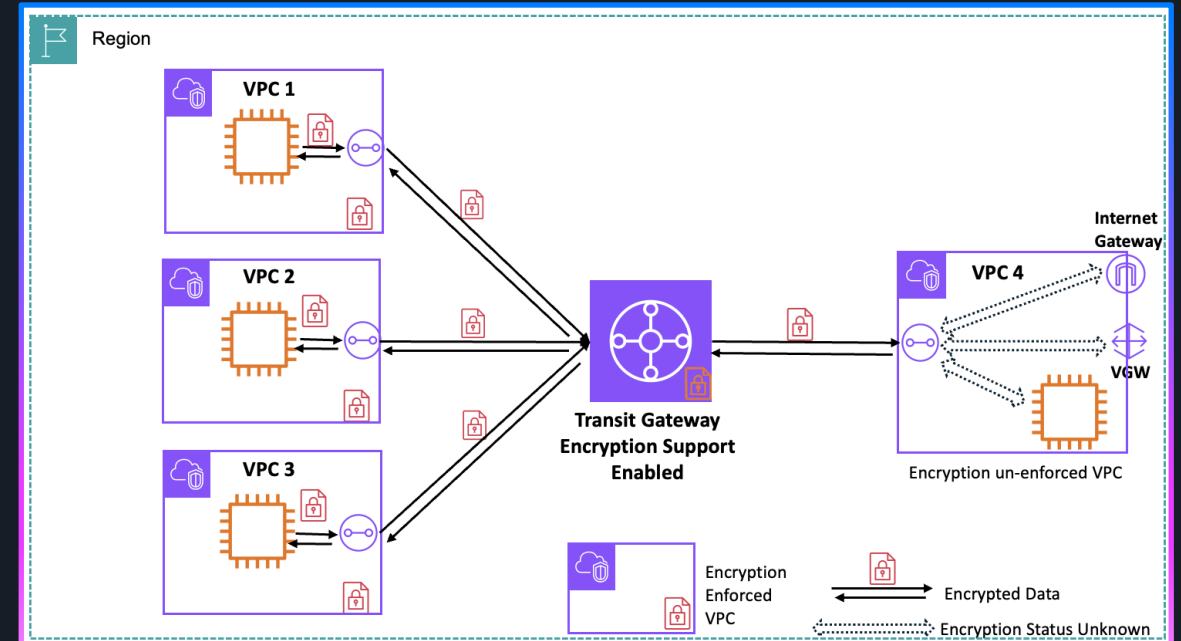


Diagram shows VPC encryption support for Transit Gateway. VPC 1, VPC 2 and VPC3 have encryption controls in enforce mode and they are connected to VPC 4 which has Encryption Controls running in monitor mode.

Governance



Governance launches

MOVE FASTER AND ADHERE TO SECURITY, OPERATIONAL, AND COMPLIANCE STANDARDS



AWS Organizations Transfer Billing for Channel Partners: Maintain full administrative control of their AWS Organization while routing billing through their Channel Partner



AWS Organizations Simplifying transferring Accounts Across Organizations: Directly transfer member accounts between AWS Organizations without first converting them to standalone accounts



AWS Control Tower Controls-only Experience: Deploy 750+ AWS managed controls without requiring a full AWS Control Tower implementation

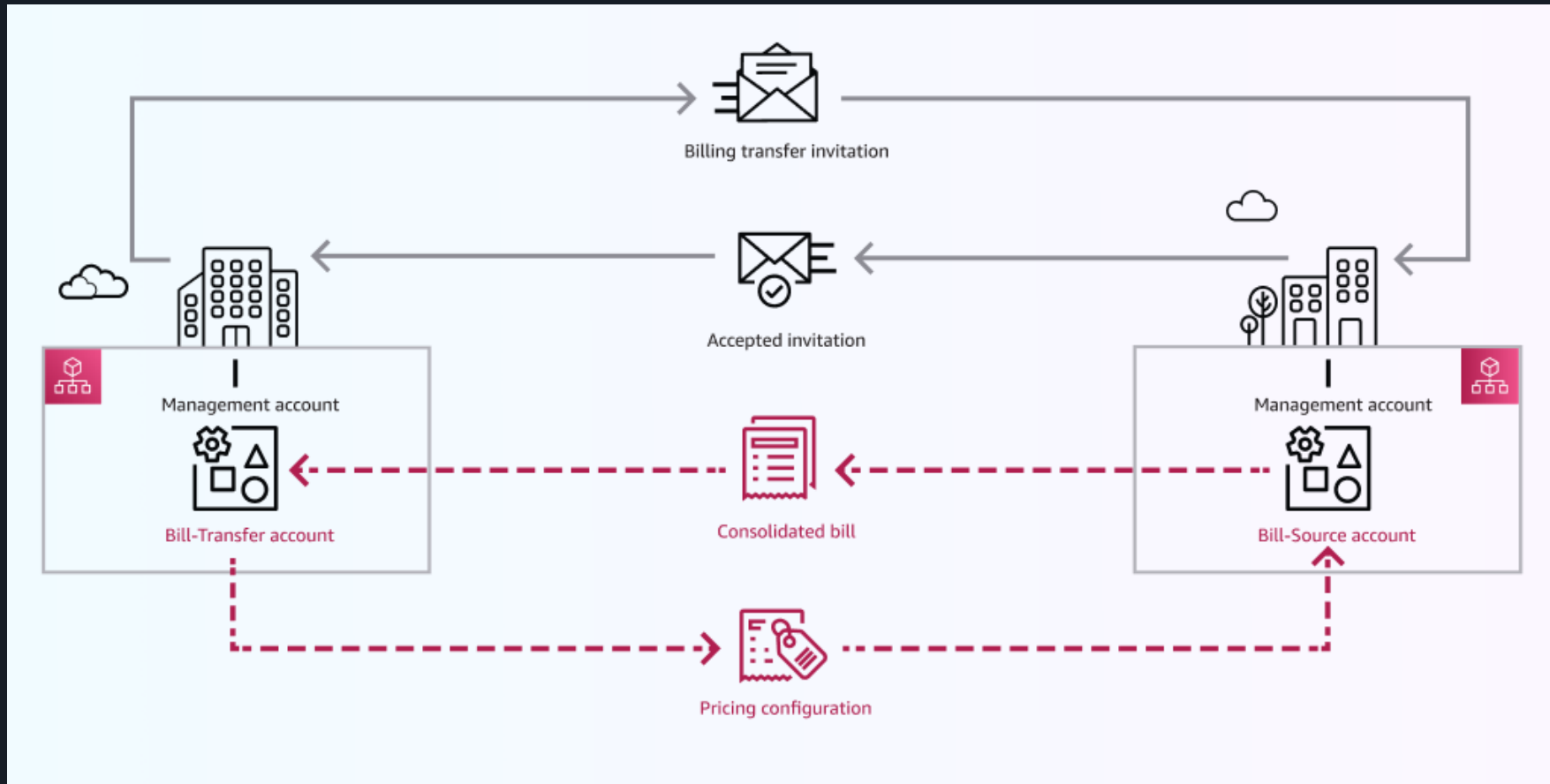


AWS Control Tower Auto-enroll Accounts: Customers are no longer required to manually update accounts or re-register OUs when migrating accounts or making changes to their OU structure



AWS Control Tower Control Library: All AWS Config rules and AWS Security Hub controls will be available in Control Catalog within AWS Control Tower

AWS Organizations Transfer Billing for Channel Partners



Transfer Accounts across Organizations

Objective: an easy way to transfer one or more accounts directly between two organizations.

Before

1. Attempt to remove member account (fails due to pre-reqs)
2. Provide payment details (pre-req)
3. Verify identity (pre-req)
4. Select support plan (pre-req)
5. Successfully remove the member account to make it standalone
6. Invite the account to join the second organization
7. Accept the invite from the standalone account

Challenges

- Slow, multi-step process
- Process varied depending on how account was originally created (within org or outside of org) and which pre-reqs were already complete
- Required temporary abandonment of orgs benefits, i.e. consolidated billing/discounts

With Transfer Accounts

1. Invite the account to join the second organization
2. Accept the invite from the member account (while still part of the first organization)

Benefits

- Fast, transfer in 2 steps (from 7)
- Standardized process steps regardless of how account was created
- Maintain- orgs benefits, i.e. billing and support during transfer

Transfer Accounts

Account Quotas



- Invites can only be set if you have room within the account quota
- Pending invites also count against your quota

Time to Accept



- 14 days to accept

Cancel Invites



- As long as they have yet to be accepted

Permissions



- Management account needs IAM permissions to send invites
- Member account needs permissions to accept invite

Delegated Admins



- Delegated admins for one or more services that integrate with AWS Organizations, need to be de-registered before leaving the org or accepting an invite

Controls Only

Objective: Enable 750+ managed AWS controls without full Control Tower deployment

Before

1. Enable Control Tower
 - Select regions
 - Establish trusted access
 - Select/Create OUs
 - Select/Create shared accounts
 - Additional configurations; e.g. IAM Identity Center, AWS Cloud Trail, AWS Config, KMS encryption, AWS backup
2. Browse Control Catalog
3. Enable desired controls

Challenges

- Full AWS Control Tower deployment required to view controls
- Multiple service configurations needed
- Organizations with established environments need to adapt to AWS Control Tower's best practices

With Control Only

1. Browse Control Catalog (ungated)
2. Enable Control Tower (minimal setup)
 - Select regions
 - Establish trusted access
 - Optional: Configure AWS Config for detective controls
3. Enable desired controls

Benefits

- Preview controls without AWS Control Tower enablement
- Choose only the governance features you need
- Preserve your organization's established existing multi-account environment
- Start with essential controls, expand when ready

Additional Key Launches



Observability, Security and Compliance

CONVERGING AWS DATA STORES INTO A SINGLE DATA STORE ON CLOUDWATCH

Centralized Data Collection

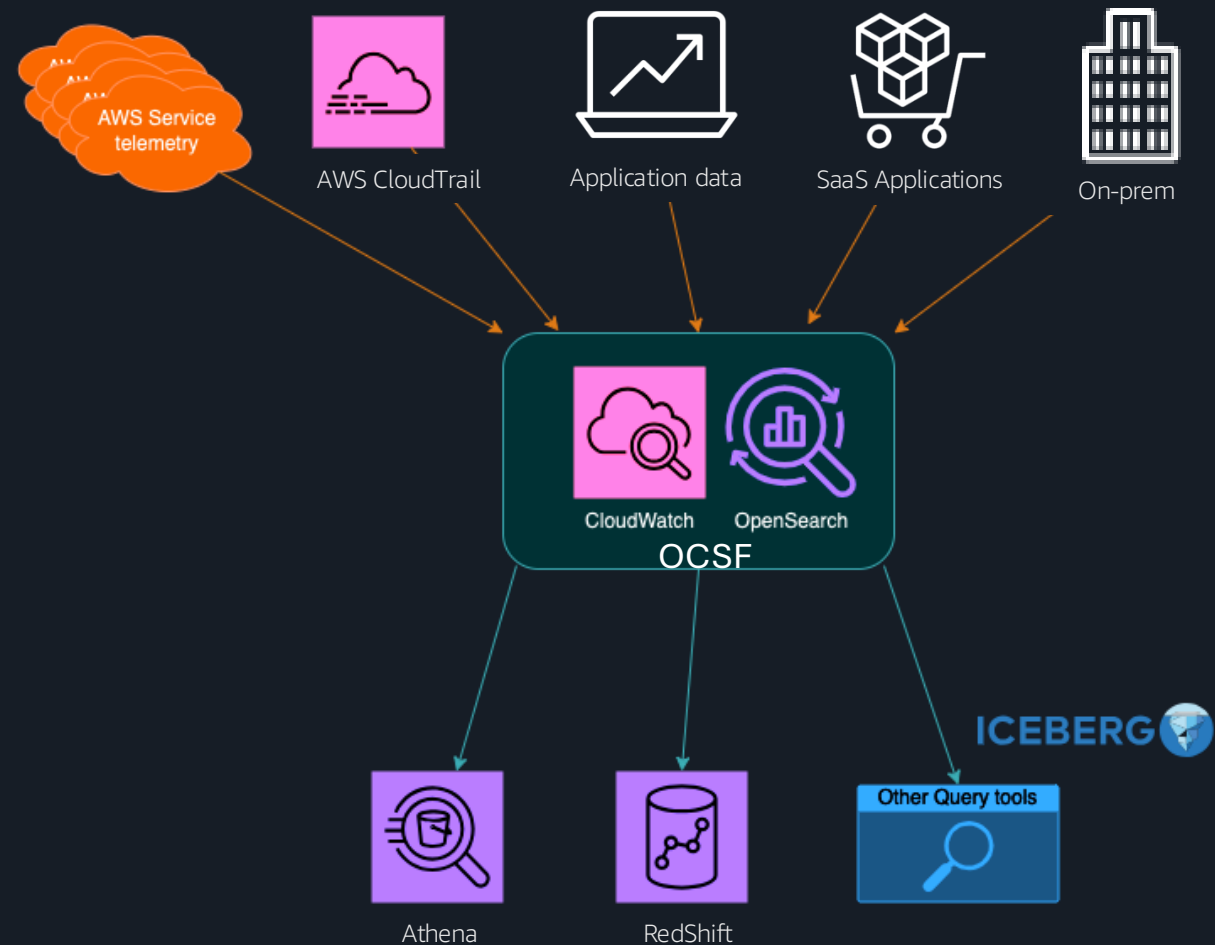
- For AWS, 3P and custom logs with ingress processing (transformation, filtering enrichment)

Built In Analytics

- Tailored to security and observability
- Powerful data analytics with OpenSearch

Flexible Data Consumption

- Use any analytics tool
- Stream or access data in place
- Controlled access to data sets



<https://aws.amazon.com/blogs/aws/amazon-cloudwatch-introduces-unified-data-management-and-analytics-for-operations-security-and-compliance/>

© 2025, Amazon Web Services, Inc. or its affiliates. All rights reserved.

AWS Security Reference Architecture (AWS SRA)

BLUEPRINT TO BUILD A SECURE, SCALABLE MULTI-ACCOUNT FOUNDATION FOR CRITICAL APPS ON AWS

Why SRA Matters?

- Pre-built, comprehensive security architecture designed by AWS experts
- Reduces time-to-security from months to days
- Help avoid costly security redesigns and compliance gaps
- Design guidance helps design, [SRA Verify](#) helps validate existing environment and [SRA Code library](#) helps build
- Design consideration to customize the framework

Key Business Benefits

- Accelerated cloud adoption with confidence
- Reduces security risks and compliance complexity
- Promote security first culture through architectural approach
- Saves costs through standardized, proven security patterns embedded into design
- Enables scalable security across multiple accounts and workloads

Customer Adoption

- Leveraged by enterprise and SMB customers across HCLS, hospitality, Education, Aviation
- Used by MSSP and ISV partners
- 1M+ users of guidance and code base
- Integrated with Landing Zone Accelerator, Security MSSP competency program, AWS Well-Architected and SHIP program

NEXT STEPS

1. Talk to customers about their security architecture
2. Validate using verify
3. Build a plan to align to SRA
4. Capture customer feedback (VoC)





Thank you